

Anexo de Evidencias

INC-2026-001 — Compromiso de host y acceso no autorizado a datos de pago

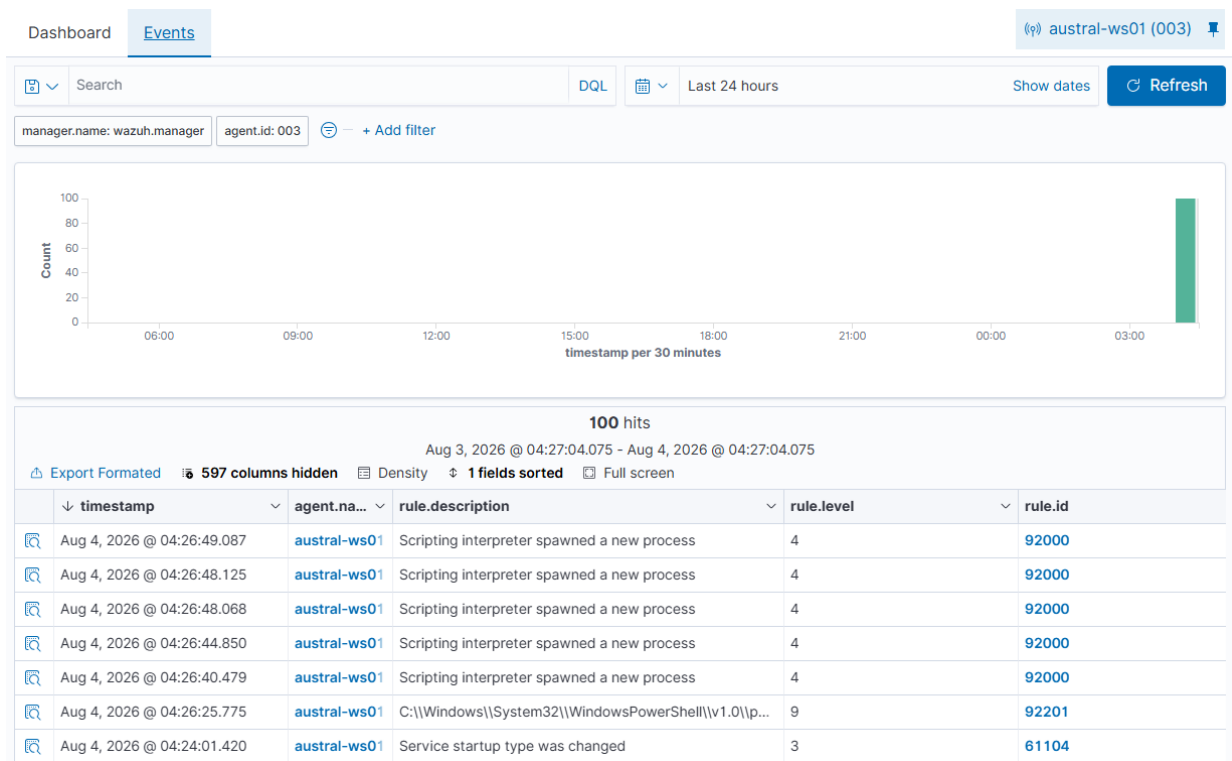
AustralPay es una organización ficticia creada exclusivamente con fines de laboratorio y portafolio. Este anexo es un ejercicio de análisis; ninguna infraestructura, dato o incidente descrito corresponde a una empresa real.

Este anexo respalda visualmente el informe **INC-2026-001**. Cada evidencia (E01–E12) corresponde a un punto del timeline (columna *Ev.* del informe). Convención: **DETECTADO** = el SOC generó alerta; **SILENCIOSO / GAP** = acción no detectada, reconstruida en la investigación; **CONTEXTO** = evento de bajo nivel sin valor de alerta. Timestamps de laboratorio; referencia horaria en UTC en el informe.

E01 Initial Access — linaje wscript → powershell

Táctica: Initial Access | MITRE: T1566 → T1059.005 | Detección: CONTEXTO (regla 92000, nivel 4)

Sysmon Event ID 1 con **parentImage = wscript.exe** generando **powershell.exe**. Relación padre-hijo anómala = huella del vector de entrada vía el .js señuelo.

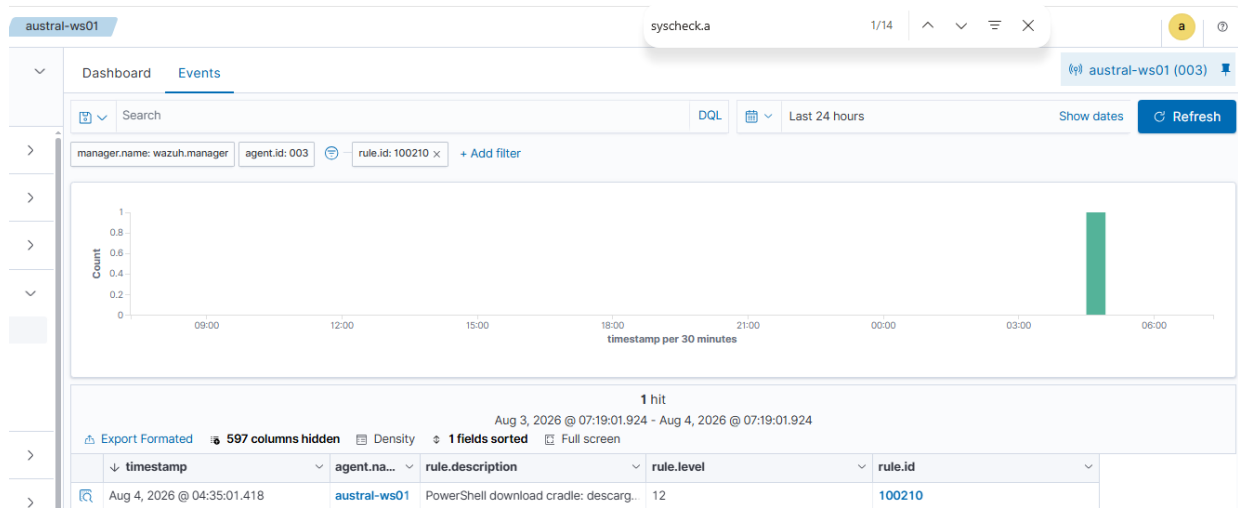


Archivo en repo: evidencia/E01-phishing-linaje.png

E02 Execution — download-cradle (alerta 100210)

Táctica: Execution | MITRE: T1059.001 | Detección: **DETECTADO** (regla 100210, nivel 12)

Regla custom **100210** filtrada: 1 hit, nivel 12. commandLine con **IEX + Net.WebClient.DownloadString**. Detección de la ejecución en memoria.



Archivo en repo: evidencia/E02-cradle-100210.png

E03 Persistence — Run key (gap de regla)

Táctica: Persistence | MITRE: T1547.001 | Detección: **SILENCIOSO / GAP** (Sysmon EID 13, sin alerta Wazuh)

Get-WinEvent en el endpoint: Event ID 13 (RuleName: T1060,RunKey, TargetObject ...\\Run\\AustralUpdater). El sensor lo vio; Wazuh no lo promovió → gap de **regla**, no de sensor.

```
Administrador: Windows PowerShell

Windows PowerShell
Copyright (C) Microsoft Corporation. Todos los derechos reservados.

Prueba la nueva tecnología PowerShell multiplataforma https://aka.ms/pscore6

PS C:\Windows\system32>
PS C:\Windows\system32> Get-WinEvent -FilterHashtable @{LogName='Microsoft-Windows-Sysmon/Operational'; Id=13} -MaxEvents 100 -ErrorAction SilentlyContinue | Where-Object { $_.Message -like '*AustralUpdater*' } | Format-List TimeCreated, Message

TimeCreated : 04-08-2026 4:50:25
Message      : Registry value set:
               RuleName: T1060,RunKey
               EventType: SetValue
               UtcTime: 2026-08-04 08:50:25.362
               ProcessGuid: {08414c69-a098-6a71-6901-000000000800}
               ProcessId: 5244
               Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
               TargetObject: HKU\S-1-5-21-1880084329-2147108672-775970409-1001\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\AustralUpdater
               Details: powershell.exe -NoProfile -WindowStyle Hidden -Command Write-Output persistence-lab
               User: AUSTRAL-WS01\austral-ws01

PS C:\Windows\system32> (Get-WinEvent -FilterHashtable @{LogName='Microsoft-Windows-Sysmon/Operational'; Id=13} -MaxEvents 100 -ErrorAction SilentlyContinue | Where-Object { $_.Message -like '*AustralUpdater*' } | Format-List TimeCreated, Message)
```

Archivo en repo: evidencia/E03-persistencia-runkey.png

E04 Credential Access — robo de credencial en texto plano

Táctica: Credential Access | MITRE: T1552.001 | Detección: **SILENCIOSO / GAP** (lectura no monitoreada)

Lectura de **accesos-servidores.txt** exponiendo la credencial de **soporte-pagos** (usuario, password y comando de conexión al servidor de pagos).

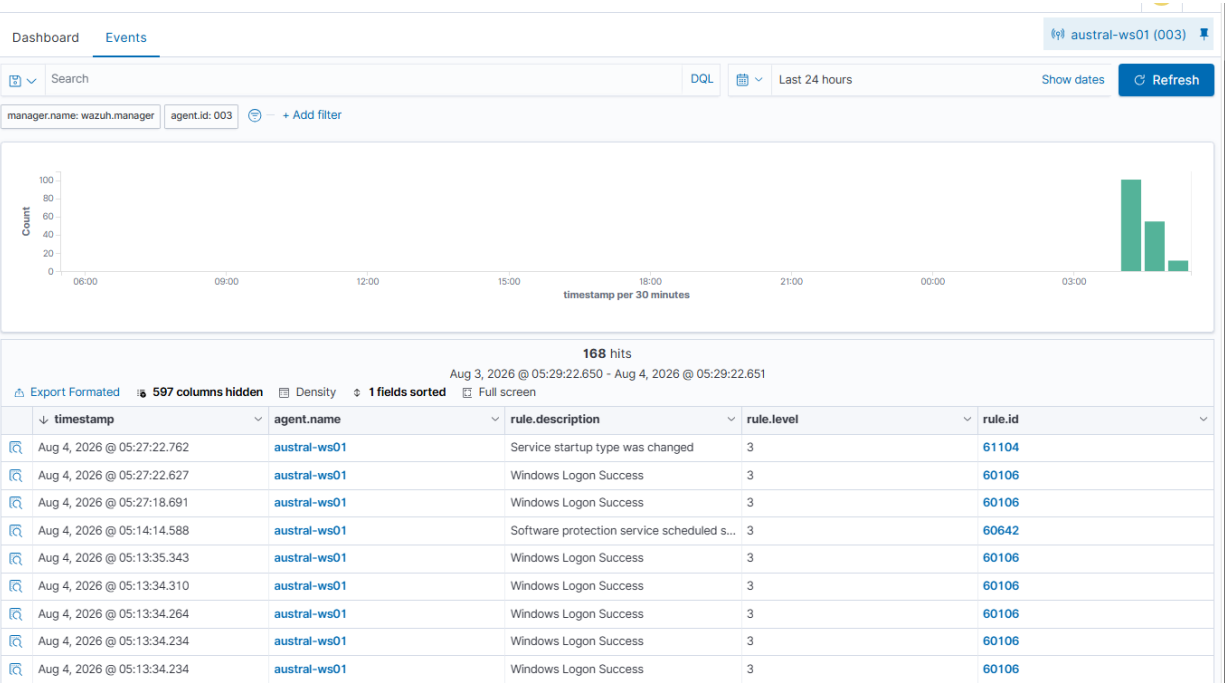
```
PS C:\Users\austral-ws01>
PS C:\Users\austral-ws01>
PS C:\Users\austral-ws01> Get-Content (Join-Path $env:USERPROFILE 'Documents\accesos-servidores.txt')
# Accesos servidores - NO BORRAR (uso interno operaciones)
# AustralPay - lab ficticio
Servidor de pagos (austral-app): 192.168.1.55
Usuario: soporte-pagos
Password: 
Conexion: ssh soporte-pagos@192.168.1.55
PS C:\Users\austral-ws01>
```

Archivo en repo: evidencia/E04-robo-credencial.png

E05 Credential Access — robo sin detección (punto ciego)

Táctica: Credential Access | MITRE: T1552.001 | Detección: **SILENCIOSO / GAP** (ausencia de alerta)

Dashboard de austral-ws01 en la ventana de la lectura: solo ruido de rutina (60106, 60642), **ninguna alerta del robo**. La ausencia es la evidencia: leer un archivo no genera evento.

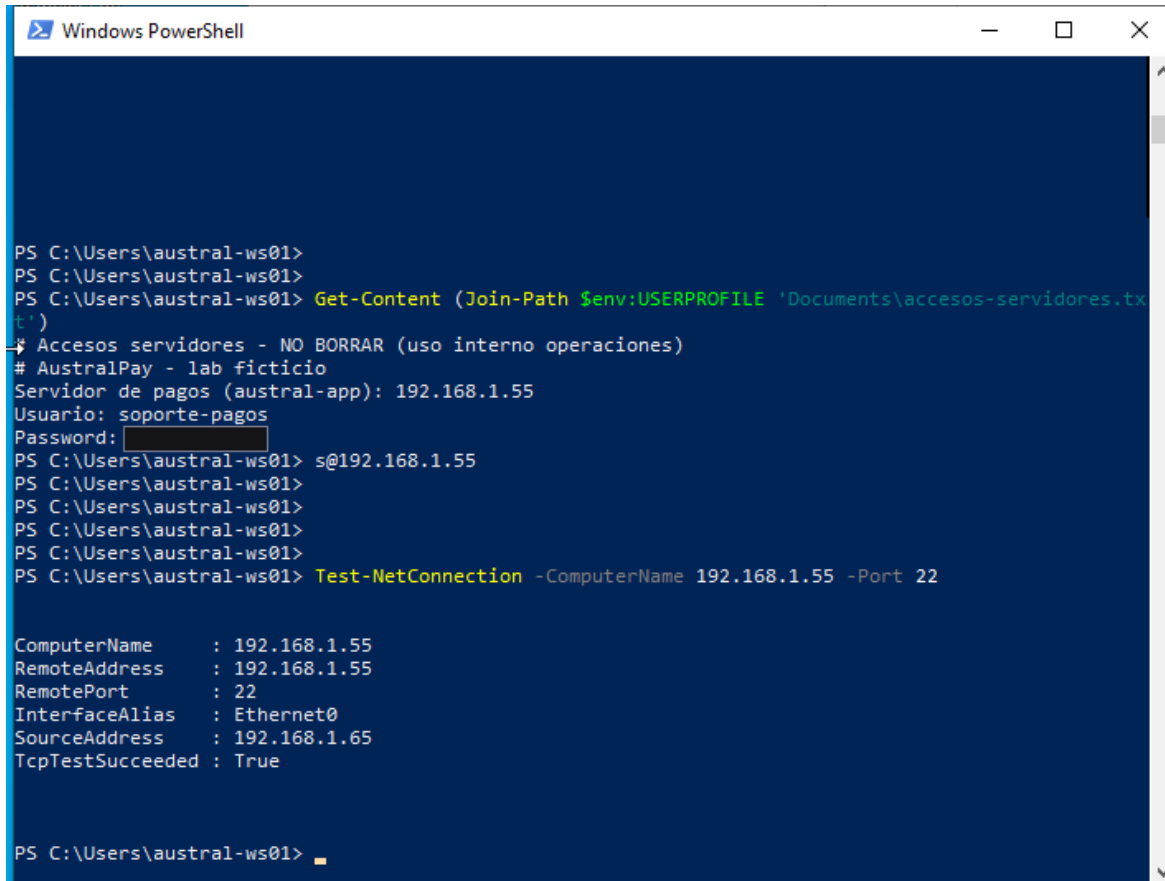


Archivo en repo: evidencia/E05-robo-sin-deteccion.png

E06 Discovery — reconocimiento del servidor de pagos

Táctica: Discovery | MITRE: T1046 | Detección: **SILENCIOSO / GAP** (gap inherente)

Test-NetConnection 192.168.1.55 -Port 22 → TcpTestSucceeded: True. Confirma el SSH del objetivo abierto antes del salto lateral. Herramienta nativa, no detectada.



```
Windows PowerShell

PS C:\Users\austral-ws01>
PS C:\Users\austral-ws01>
PS C:\Users\austral-ws01> Get-Content (Join-Path $env:USERPROFILE 'Documents\accesos-servidores.txt')
# Accesos servidores - NO BORRAR (uso interno operaciones)
# AustralPay - lab ficticio
Servidor de pagos (austral-app): 192.168.1.55
Usuario: soporte-pagos
Password:
PS C:\Users\austral-ws01> s@192.168.1.55
PS C:\Users\austral-ws01>
PS C:\Users\austral-ws01>
PS C:\Users\austral-ws01>
PS C:\Users\austral-ws01>
PS C:\Users\austral-ws01> Test-NetConnection -ComputerName 192.168.1.55 -Port 22

ComputerName      : 192.168.1.55
RemoteAddress     : 192.168.1.55
RemotePort        : 22
InterfaceAlias    : Ethernet0
SourceAddress     : 192.168.1.65
TcpTestSucceeded  : True

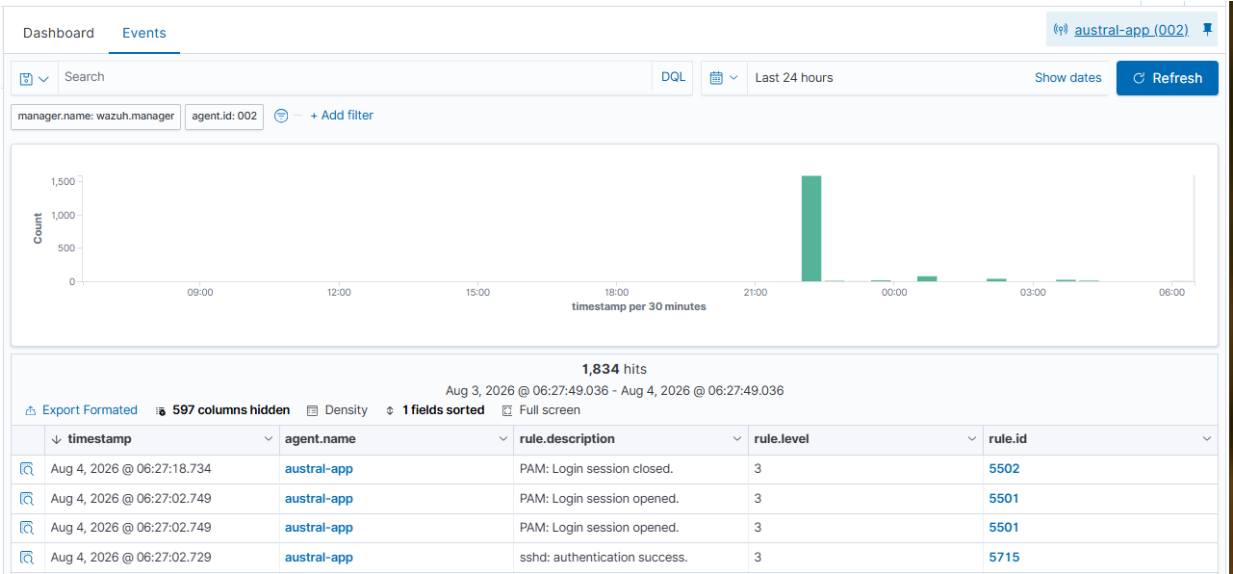
PS C:\Users\austral-ws01>
```

Archivo en repo: evidencia/E06-reconocimiento-ssh.png

E07 Lateral Movement — credencial válida (sin alerta)

Táctica: Lateral Movement | MITRE: T1078 | Detección: SILENCIOSO / GAP (login de rutina, nivel 3)

Login SSH exitoso a austral-app como soporte-pagos desde .65, sin fallos. Solo un 5715 nivel 3 (+ PAM). Indistinguible de un login legítimo. Blind spot central del caso.

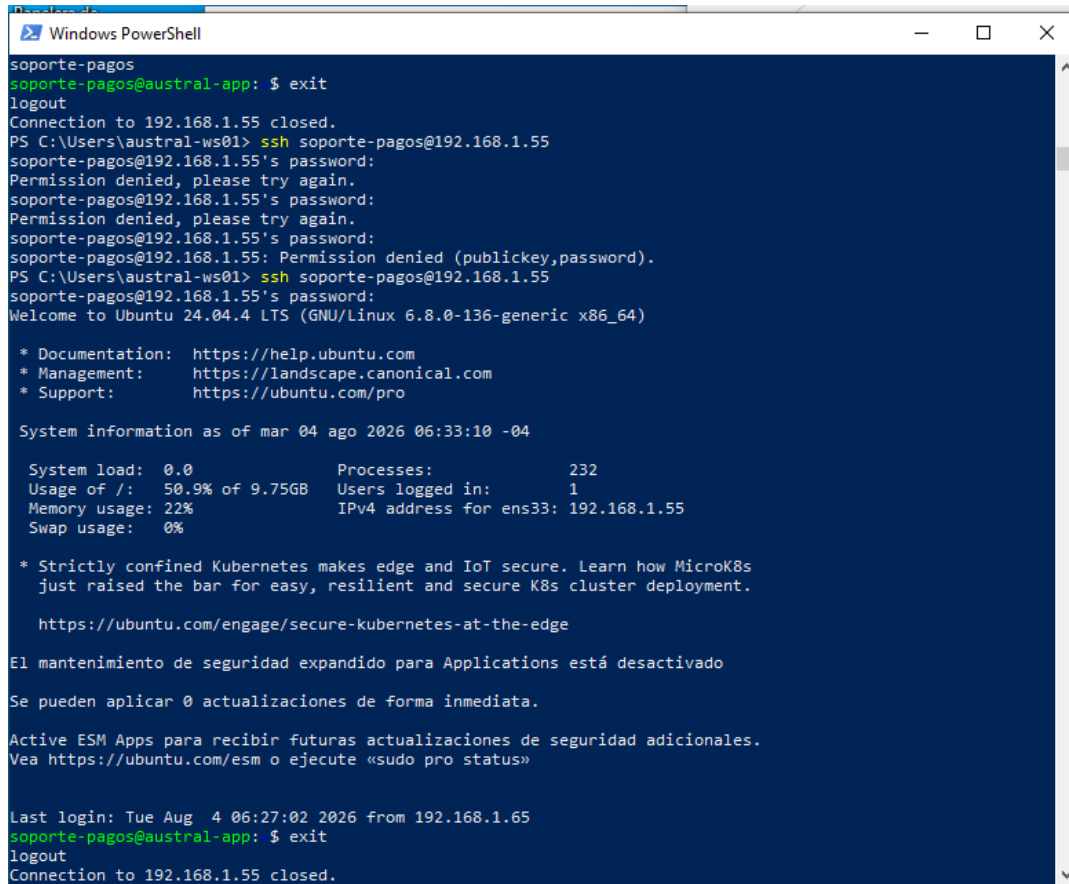


Archivo en repo: evidencia/E07-lateral-credencial-valida.png

E08 Lateral Movement — brute force (terminal atacante)

Táctica: Lateral Movement | MITRE: T1110.001 | Detección: **DETECTADO** (ver E09)

Lado atacante: tres **Permission denied** seguidos de acceso exitoso. El patrón fallo→éxito es lo que la regla 100220 correlaciona.



```
soporte-pagos
soporte-pagos@austral-app: $ exit
logout
Connection to 192.168.1.55 closed.
PS C:\Users\austral-ws01> ssh soporte-pagos@192.168.1.55
soporte-pagos@192.168.1.55's password:
Permission denied, please try again.
soporte-pagos@192.168.1.55's password:
Permission denied, please try again.
soporte-pagos@192.168.1.55's password:
soporte-pagos@192.168.1.55: Permission denied (publickey,password).
PS C:\Users\austral-ws01> ssh soporte-pagos@192.168.1.55
soporte-pagos@192.168.1.55's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-136-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of mar 04 ago 2026 06:33:10 -04

System load:  0.0          Processes:            232
Usage of /:   50.9% of 9.75GB Users logged in:      1
Memory usage: 22%         IPv4 address for ens33: 192.168.1.55
Swap usage:   0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

El mantenimiento de seguridad expandido para Applications está desactivado

Se pueden aplicar 0 actualizaciones de forma inmediata.

Active ESM Apps para recibir futuras actualizaciones de seguridad adicionales.
Vea https://ubuntu.com/esm o ejecute «sudo pro status»

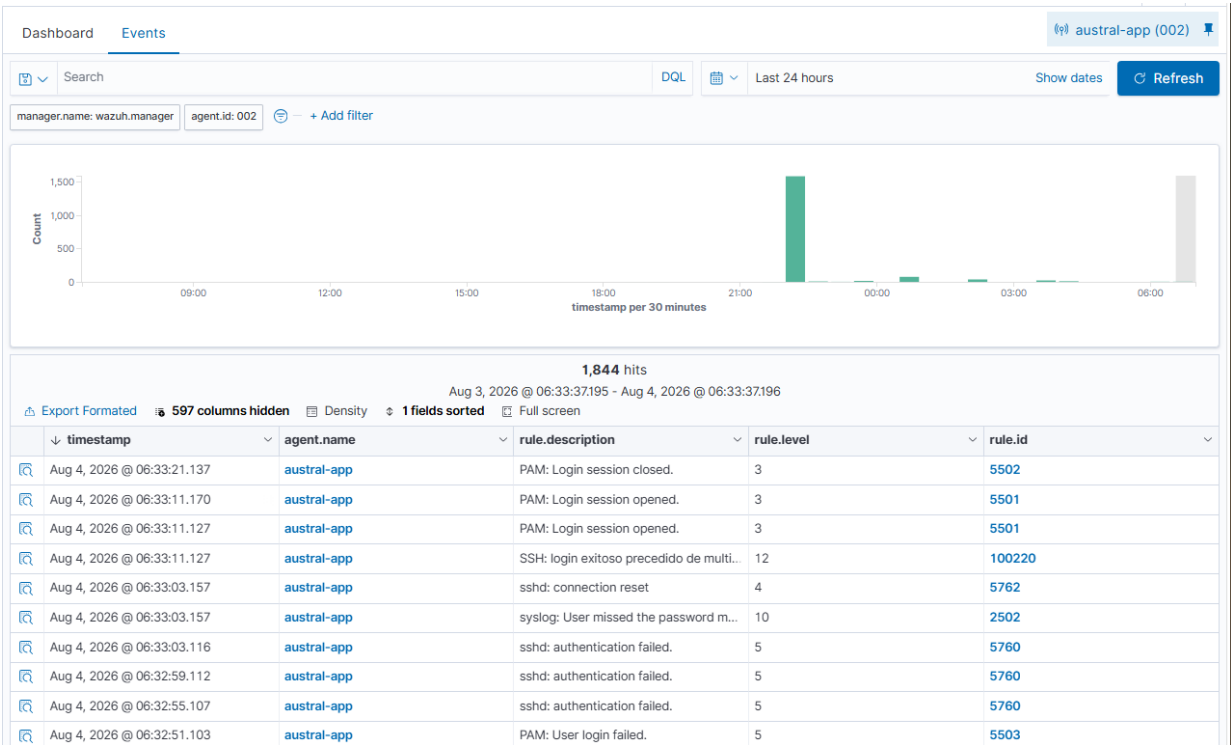
Last login: Tue Aug  4 06:27:02 2026 from 192.168.1.65
soporte-pagos@austral-app: $ exit
logout
Connection to 192.168.1.55 closed.
```

Archivo en repo: evidencia/E08-bruteforce-terminal.png

E09 Lateral Movement — brute force detectado (alerta 100220)

Táctica: Lateral Movement | MITRE: T1110.001 / T1078 | Detección: **DETECTADO** (regla 100220, nivel 12)

Dashboard: **100220, nivel 12**, precedida de 5760 (fallos), 2502 y 5762. El disparador de la investigación. Contraste directo con E07: mismo objetivo, distinto método, distinto resultado.



Archivo en repo: evidencia/E09-bruteforce-100220.png

E10 Impact — lectura de datos y techo de permisos

Táctica: Collection / Impact | MITRE: T1005 | Detección: **SILENCIOSO / GAP** (lectura) / previo a escalada

El atacante lee el **transacciones.csv** completo (cat) — exfiltración simulada, silenciosa — e intenta modificarlo: **Permission denied** con la cuenta soporte-pagos. Este techo motiva la escalada (E11).

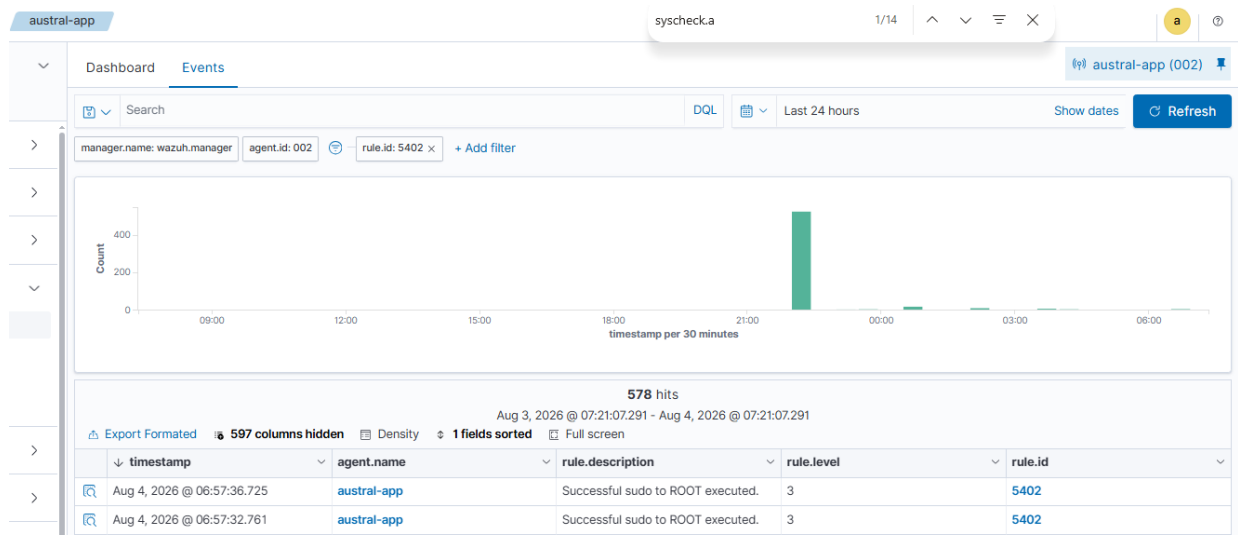
```
Last login: Tue Aug 4 06:33:10 2026 from 192.168.1.65
soporte-pagos@austral-app:~$ cat /opt/austral-app/data/transacciones.csv
# DATA SINTETICA DE LABORATORIO - AustralPay (organizacion ficticia). Numeros de tarjeta de PRUEBA estandar,
no corresponden a tarjetas reales.
id_transaccion,fecha,comercio,titular,tarjeta_pan,monto_clp,estado
TX-100001,2026-07-28,MercadoAustral SpA,Camila Fuentes,4111111111111111,45990,aprobada
TX-100002,2026-07-28,Delivery Nube,Rodrigo Tapia,5555555555554444,12500,aprobada
TX-100003,2026-07-29,Suscripciones Andes,Valentina Rojas,378282246310005,8990,aprobada
TX-100004,2026-07-29,MercadoAustral SpA,Ignacio Moreno,6011111111111117,132400,rechazada
TX-100005,2026-07-30,Ticketera Sur,Francisca Vega,4012888888881881,23000,aprobada
TX-100006,2026-07-30,Delivery Nube,Sebastian Cortes,5105105105105100,15750,aprobada
TX-100007,2026-07-31,Farmacia Cordillera,Antonia Silva,371449635398431,6490,aprobada
TX-100008,2026-07-31,Suscripciones Andes,Matias Bravo,30569309025904,8990,aprobada
soporte-pagos@austral-app:~$ echo "TX-666999,2026-08-04,ATACANTE,exfil,0000000000000000,999999,comprometido"
>> /opt/austral-app/data/transacciones.csv
-bash: /opt/austral-app/data/transacciones.csv: Permission denied
soporte-pagos@austral-app:~$ exit
logout
Connection to 192.168.1.55 closed.
PS C:\Users\austral-ws01>
```

Archivo en repo: evidencia/E10-lectura-techo-permisos.png

E11 Privilege Escalation — escalada por sudo (alerta 5402)

Táctica: Privilege Escalation | MITRE: T1548.003 | Detección: **DETECTADO** (regla 5402, nivel 3)

Dashboard filtrado rule.id 5402: **"Successful sudo to ROOT executed"**, agente austral-app. El cruce del control auditado (sudo) con la credencial robada. Timestamp del ataque: 10:57 UTC.



Archivo en repo: evidencia/E11-escalada-sudo-5402.png

E12 Impact — modificación con atribución (FIM whodata, alerta 550)

Táctica: Impact | MITRE: T1565.001 | Detección: **DETECTADO** (regla 550, nivel 7)

Campos **syscheck.audit** (whodata) de la alerta 550: **login_user = soporte-pagos** (uid 1001) → **effective_user = root** (uid 0) → **process = /usr/bin/tee** con **parent = /usr/bin/sudo**. Prueba de quién modificó el dato y cómo escaló, en un solo evento.

t	syscheck.audit.effective_user.id	0
t	syscheck.audit.effective_user.name	root
t	syscheck.audit.group.id	0
t	syscheck.audit.group.name	root
t	syscheck.audit.login_user.id	1001
t	syscheck.audit.login_user.name	soporte-pagos
?	syscheck.audit.process.cwd	/home/soporte-pagos
t	syscheck.audit.process.id	131603
t	syscheck.audit.process.name	/usr/bin/tee
?	syscheck.audit.process.parent_cwd	/home/soporte-pagos
?	syscheck.audit.process.parent_name	/usr/bin/sudo
t	syscheck.audit.process.ppid	131602
t	syscheck.audit.user.id	0
t	syscheck.audit.user.name	root

Archivo en repo: evidencia/E12-impacto-fim-550.png